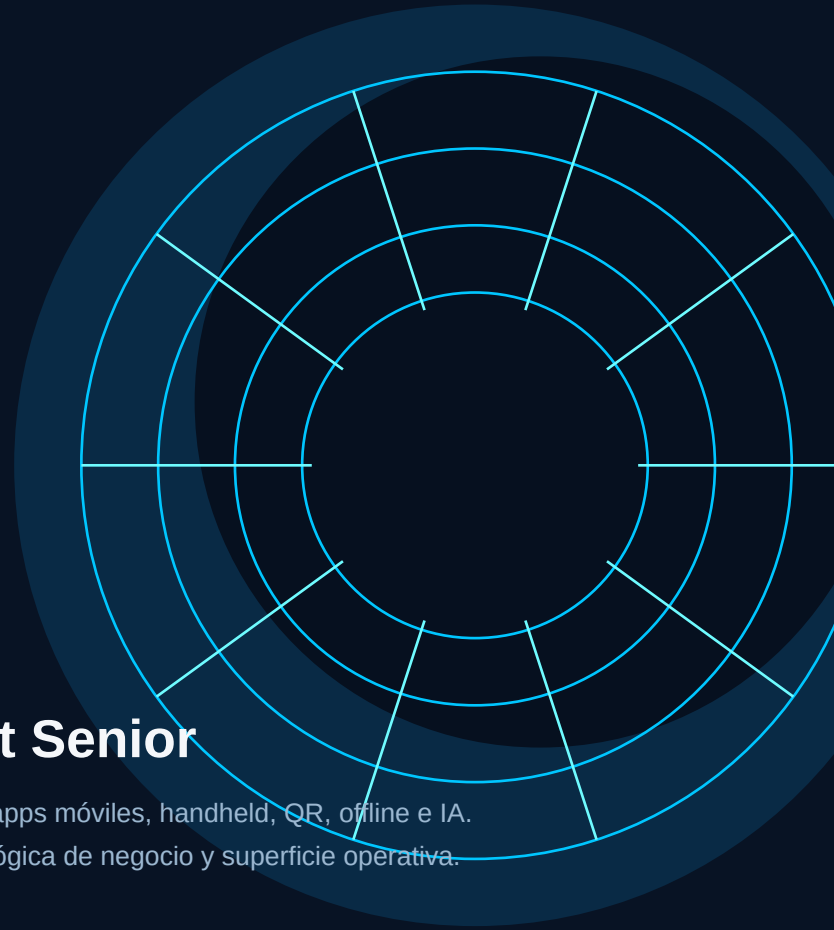


XTRAVON ONE

GRAIN CONTROL

Reporte Técnico de Pentest Senior

Evaluación integral de seguridad del backend, escritorio, apps móviles, handheld, QR, offline e IA.
Enfoque: revisión estática senior, arquitectura, abuso de lógica de negocio y superficie operativa.



QORA SYSTEMS - Alianza con MSL Marine Surveyors and Logistics Group

Documento confidencial | Uso interno y comercial controlado | Versión 1.0

Resumen Ejecutivo

La revisión senior de seguridad cubrió el backend FastAPI, base de datos PostgreSQL, cliente escritorio Tkinter/PyInstaller, apps móviles Expo por variante, flujo handheld Zebra, QR/HMAC, operación offline, RBAC/TOTP, releases, reportes y PORTIA. El producto tiene una base funcional amplia y controles relevantes ya implementados; sin embargo, por su naturaleza portuaria y por operar con QR, asignaciones, cuotas, handhelds y datos de clientes, el riesgo residual se mantiene **MEDIO-ALTO** hasta cerrar los controles de tenant scoping, cifrado offline, firma de releases, RBAC fino y pruebas de abuso de negocio.

Estado global

Riesgo residual MEDIO-ALTO. No se identificó evidencia de explotación activa, pero sí controles pendientes antes de despliegue comercial amplio.

Fortalezas

QR con HMAC, TOTP para perfiles altos, PBKDF2, auditoría, operation_id reforzado, offline queue y circuit breaker IA.

Prioridad

Cerrar aislamiento por empresa/operación, cifrado offline, firma de actualizaciones y permisos por endpoint.

Distribución de hallazgos por severidad



Madurez técnica estimada por dominio (0-5)

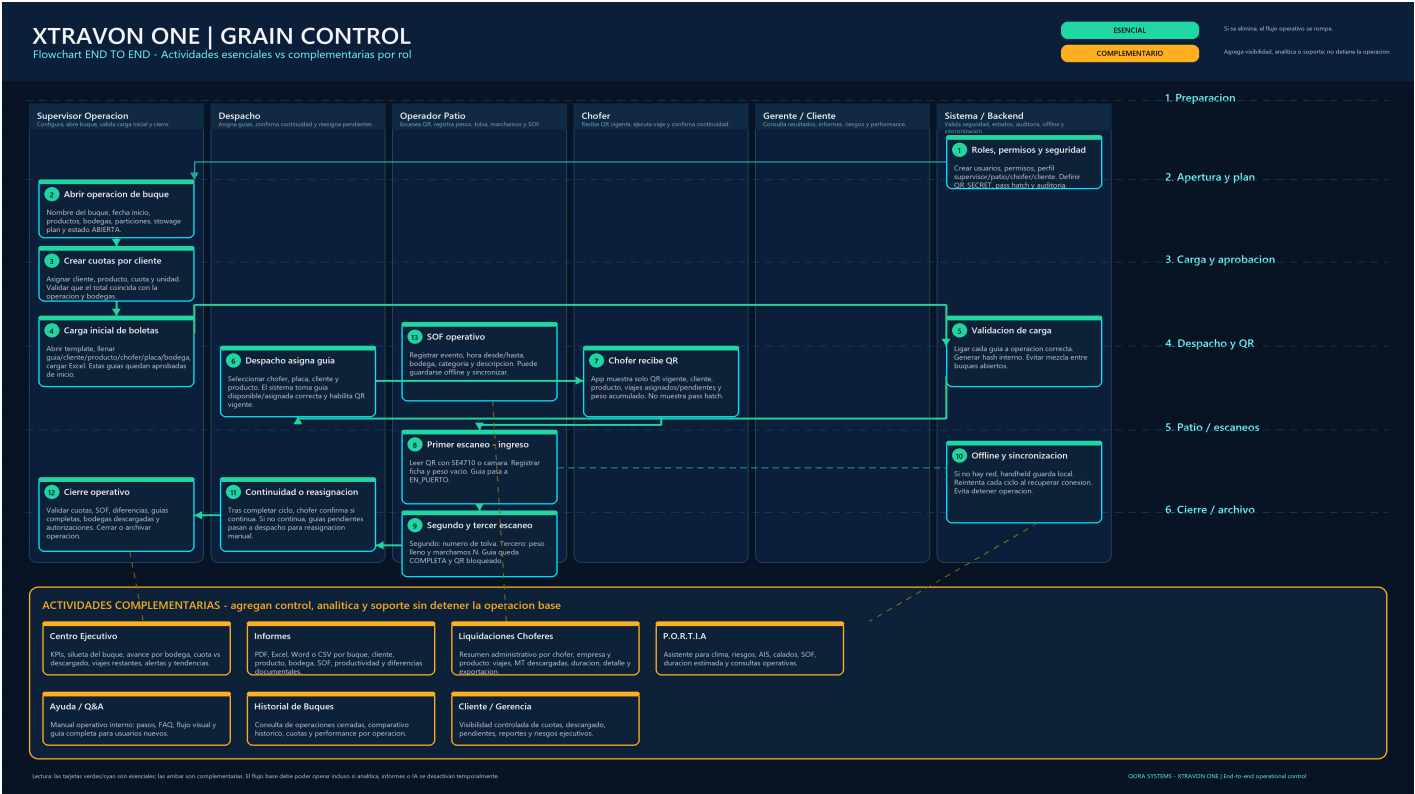


Alcance y Metodología

Este reporte corresponde a una revisión de pentest senior basada en inspección de código, arquitectura, configuración, flujos de negocio y evidencia funcional observada durante la construcción del ERP. No se ejecutaron pruebas destructivas contra producción ni explotación activa de credenciales. El foco fue identificar brechas explotables, abusos de lógica de negocio, riesgos de operación offline, entrega de QR, autenticación, autorización, integridad de datos y cadena de suministro.

Dominio	Componentes revisados	Riesgos analizados
Backend	FastAPI, routers, servicios QR, RBAC, despacho, aprobaciones, liquidaciones, auditoría, PORTIA.	Autorización, secretos, CORS, DDL runtime, inyección, DoS, errores, auditoría.
Desktop	Tkinter, login, Windows Hello/PIN, Inno Setup, releases, centro ejecutivo, operaciones, SOF.	Credenciales locales, actualización remota, UX segura, exposición de datos, permisos.
Mobile	Apps supervisor, chofer y handheld, Expo, OTA, QR, offline cache, DataWedge/Zebra.	Cache offline, spoofing de escaneo, variantes, API hardcoded, pérdida de dispositivo.
Negocio	Cuotas, asignación, reasignación, escaneos, liquidaciones, SOF, reportes.	Sobrecuota, mezcla de operaciones, robo documental, trazabilidad incompleta.

Referencia visual del flujo operativo



Superficie de Ataque

Vector	Exposición	Control actual	Riesgo residual
QR operativo	Ingreso/salida/tolva/planta/bodega, entrega por app/correo/WhatsApp.	HMAC-SHA256, QR activo, pass hatch oculto, etapas.	Alto si hay secretos débiles, reenvíos o validación offline incompleta.
Handheld offline	Operación en puerto con señal intermitente.	Cache, cola de sincronización, validación local.	Alto si no hay cifrado, MDM y borrado remoto.
Desktop supervisor	Operaciones, cuotas, aprobaciones, despacho, reportes.	Login, TOTP, roles, Windows Hello.	Medio por permisos finos y releases.
API backend	Railway, PostgreSQL, endpoints móviles/desktop.	RBAC, CORS, QR secret, circuit breaker.	Medio-Alto por scoping y DDL runtime.
IA/PORTIA	Consultas operativas, clima, AIS, puertos, reportes.	Circuit breaker y respuestas prudentes.	Medio por privacidad y proveedores externos.

Matriz de Hallazgos

ID	Severidad	Hallazgo	Impacto principal
PENT-01	Alto	Aislamiento por empresa/cliente no garantizado end-to-end	Riesgo de exposición cruzada de cuotas, viajes, reportes o QR entre clientes de una misma operación.
PENT-02	Alto	QR_SECRET y AUTH_SECRET requieren ciclo de vida formal	Un secreto débil, reutilizado o filtrado permitiría falsificación de tokens o QR.
PENT-03	Alto	Cache offline sensible en handheld/app	Pérdida o robo de handheld podría exponer datos de operación, choferes o guías cacheadas.
PENT-04	Alto	Cobertura RBAC endpoint por endpoint	Usuarios con rol amplio podrían ejecutar acciones fuera de su función.
PENT-05	Alto	Supply chain de actualización desktop	Ataque de reemplazo de instalador o downgrade podría comprometer estaciones.
PENT-06	Medio	DDL dentro de routers/servicios	Riesgo de drift de esquema, fallos de arranque y cambios no auditados en producción.
PENT-07	Medio	Ingesta Excel y superficie de DoS	Archivos malformados o muy grandes podrían degradar servicio o insertar datos inconsistentes.
PENT-08	Medio	CORS y configuración por ambiente	Riesgo de origen no esperado si se relajan variables en producción.
PENT-09	Medio	PORTIA/IA y proveedores externos	Fuga accidental de datos sensibles o respuestas con exceso de confianza operativa.
PENT-10	Medio	API base por defecto en app	Build equivocado podría apuntar a ambiente incorrecto.
PENT-11	Medio	Auditoría no completamente tamper-evident	Un actor con acceso DB podría alterar auditoría histórica.
PENT-12	Medio	Manejo de errores e información técnica	Exposición de implementación y pérdida de confianza operativa.
PENT-13	Medio	Hardening de escaneo Zebra/DataWedge	Lecturas spoofed o perfil mal configurado podrían saltarse validaciones de app.
PENT-14	Alto	Abuso de lógica de negocio por cuota y reasignación	Sobre-retiro, robo documental o reasignación indebida.
PENT-15	Medio	Disponibilidad ante cargas, reportes e IA	Lentitud, timeouts y 502 durante operación crítica.
PENT-16	Medio	Entrega QR por correo/WhatsApp	QR reenviado o entregado a número/correo incorrecto.
PENT-17	Bajo	Exposición de artefactos de releases	No compromete por sí solo, pero facilita fingerprinting.
PENT-18	Medio	MFA bootstrap y recuperación	Riesgo de bloqueo operativo o enrollment por persona incorrecta.
PENT-19	Alto	Aislamiento multi-operación	Guías, QR, SOF o reportes podrían mezclarse entre operaciones abiertas.
PENT-20	Medio	Credenciales desktop y Windows Hello	Credential stuffing local, UX insegura o almacenamiento indebido.

Detalle Técnico de Hallazgos

PENT-01 | Alto | Aislamiento por empresa/cliente no garantizado end-to-end

Evidencia: El modelo requiere acceso por empresa que puede variar por buque. La revisión muestra operación_id reforzado, pero el scoping por empresa/cliente todavía debe aplicarse de forma transversal en consultas, reportes, liquidaciones, app chofer y filtros.

Impacto: Riesgo de exposición cruzada de cuotas, viajes, reportes o QR entre clientes de una misma operación.

Recomendación: Crear capa de autorización por operación_id + empresa_id + rol. Agregar pruebas de contrato por endpoint y por pantalla.

PENT-02 | Alto | QR_SECRET y AUTH_SECRET requieren ciclo de vida formal

Evidencia: Existe HMAC-SHA256 y validación de longitud mínima, pero el arranque permite advertencias para no detener módulos no QR. AUTH_SECRET puede caer a fallback si no existe.

Impacto: Un secreto débil, reutilizado o filtrado permitiría falsificación de tokens o QR.

Recomendación: Exigir secretos únicos por ambiente, rotación controlada, monitoreo de arranque y invalidación de QR al rotar.

PENT-03 | Alto | Cache offline sensible en handheld/app

Evidencia: El flujo offline guarda guías, estado, cola y datos operativos. Se sanitizan hash/token/raw_qr, pero no se confirmó cifrado robusto por dispositivo.

Impacto: Pérdida o robo de handheld podría exponer datos de operación, choferes o guías cacheadas.

Recomendación: Cifrar cache con keystore nativo, expirar datos por operación, bloqueo biométrico y borrado remoto/MDM.

PENT-04 | Alto | Cobertura RBAC endpoint por endpoint

Evidencia: El login, TOTP y roles existen, pero la seguridad comercial exige permisos finos por acción: aprobar, reasignar, cerrar, exportar, auditar, enviar QR y administrar usuarios.

Impacto: Usuarios con rol amplio podrían ejecutar acciones fuera de su función.

Recomendación: Aplicar dependencias/guards por router y generar matriz automatizada de permisos.

PENT-05 | Alto | Supply chain de actualización desktop

Evidencia: El sistema usa instaladores/release remoto. Falta evidencia de firma de código, hash obligatorio y validación criptográfica antes de instalar.

Impacto: Ataque de reemplazo de instalador o downgrade podría comprometer estaciones.

Recomendación: Firmar instalador, publicar SHA256 firmado, bloquear downgrade y validar release antes de ejecutar.

PENT-06 | Medio | DDL dentro de routers/servicios

Evidencia: Hay creación/alteración de tablas en runtime para módulos operativos, despacho, auditoría y QR.

Impacto: Riesgo de drift de esquema, fallos de arranque y cambios no auditados en producción.

Recomendación: Migrar a Alembic/migrations versionadas y dejar runtime DDL solo como modo bootstrap controlado.

PENT-07 | Medio | Ingesta Excel y superficie de DoS

Evidencia: La carga Excel procesa plantillas con cientos de filas, QR/HMAC y validaciones. El usuario reportó lag en cargas largas.

Impacto: Archivos malformados o muy grandes podrían degradar servicio o insertar datos inconsistentes.

Recomendación: Validar tamaño, columnas, tipos, fórmulas peligrosas, duplicados y ejecutar cargas en jobs asíncronos.

PENT-08 | Medio | CORS y configuración por ambiente

Evidencia: CORS ya no es abierto absoluto, pero existe fallback restringido y métodos/headers amplios.

Impacto: Riesgo de origen no esperado si se relajan variables en producción.

Recomendación: Definir CORS_ALLOWED_ORIGINS obligatorio por ambiente y limitar métodos/headers al mínimo.

PENT-09 | Medio | PORTIA/IA y proveedores externos

Evidencia: PORTIA consulta OpenAI, clima, AIS, puertos y datos operativos. Existe circuit breaker, pero debe agregarse control de salida y privacidad contextual.

Impacto: Fuga accidental de datos sensibles o respuestas con exceso de confianza operativa.

Recomendación: Redactar PII, aplicar prompts de seguridad, limitar contexto, registrar uso y clasificar respuestas como estimadas.

PENT-10 | Medio | API base por defecto en app

Evidencia: La app soporta EXPO_PUBLIC_API_BASE_URL por variante, pero conserva valores default para Railway.

Impacto: Build equivocado podría apuntar a ambiente incorrecto.

Recomendación: Exigir API explícita en CI/CD y fallar build si no existe variable por variante.

PENT-11 | Medio | Auditoría no completamente tamper-evident

Evidencia: Hay tablas y triggers de auditoría para múltiples acciones, pero no se evidenció cadena hash inmutable.

Impacto: Un actor con acceso DB podría alterar auditoría histórica.

Recomendación: Implementar hash-chain por evento, firma HMAC de auditoría y exportación WORM.

PENT-12 | Medio | Manejo de errores e información técnica

Evidencia: Se observaron mensajes internos en UI/logs durante iteraciones: stack traces, 500, rutas y variables.

Impacto: Exposición de implementación y pérdida de confianza operativa.

Recomendación: Sanitizar errores al usuario y mantener detalle solo en logs seguros.

PENT-13 | Medio | Hardening de escaneo Zebra/DataWedge

Evidencia: El handheld usa SE4710/DataWedge y fallback de cámara. El diseño depende del perfil correcto y broadcast.

Impacto: Lecturas spoofed o perfil mal configurado podrían saltarse validaciones de app.

Recomendación: Bloquear perfil DataWedge por package, validar HMAC siempre en backend/cache y usar kiosk/MDM.

PENT-14 | Alto | Abuso de lógica de negocio por cuota y reasignación

Evidencia: Se implementaron reglas de cuota, bloqueo y reasignación, pero requieren pruebas de borde: dos operaciones, mismo chofer, guía completada, QR vencido y sobrecuota.

Impacto: Sobre-retiro, robo documental o reasignación indebida.

Recomendación: Crear suite de pruebas de abuso de negocio y transacciones DB con locks por guía/cuota.

PENT-15 | Medio | Disponibilidad ante cargas, reportes e IA

Evidencia: Excel, reportes, PDF/Word, gráficos e IA pueden generar trabajo pesado sin jobs desacoplados.

Impacto: Lentitud, timeouts y 502 durante operación crítica.

Recomendación: Colas de trabajo, cache de dashboards, timeouts cortos, circuit breakers y degradación visible.

PENT-16 | Medio | Entrega QR por correo/WhatsApp

Evidencia: El sistema prepara/envía QR por SMTP/Twilio si hay variables. Falta política de expiración, reenvío y canal seguro por destinatario.

Impacto: QR reenviado o entregado a número/correo incorrecto.

Recomendación: Confirmar destinatario, registrar entrega, permitir revocación y activar QR solo tras asignación confirmada.

PENT-17 | Bajo | Exposición de artefactos de releases

Evidencia: Los instaladores desktop se publican en releases. Si el repo es público, metadatos y versiones quedan visibles.

Impacto: No compromete por sí solo, pero facilita fingerprinting.

Recomendación: Mantener releases privados o firmados, publicar checksums y no incluir secretos en binarios.

PENT-18 | Medio | MFA bootstrap y recuperación

Evidencia: Master/supervisor usan Authenticator con QR inicial. La recuperación y reseteo deben ser controlados.

Impacto: Riesgo de bloqueo operativo o enrollment por persona incorrecta.

Recomendación: Flujo de recuperación con doble control, auditoría y expiración de QR de enrollment.

PENT-19 | Alto | Aislamiento multi-operación

Evidencia: El usuario requiere dos operaciones abiertas. Se reforzó operación_id obligatorio, pero todos los flujos deben probarse contra mezcla de buques.

Impacto: Guías, QR, SOF o reportes podrían mezclarse entre operaciones abiertas.

Recomendación: operation_id como clave obligatoria en queries, tablas, cache offline, QR y filtros.

PENT-20 | Medio | Credenciales desktop y Windows Hello

Evidencia: El login desktop integra PIN/Windows Hello y contraseña guardada. Hubo problemas de foreground y fallos de UI.

Impacto: Credential stuffing local, UX insegura o almacenamiento indebido.

Recomendación: Usar Windows Credential Manager, DPAPI, no guardar texto plano, y pruebas de foco/timeout.

Roadmap de Remediación

Ventana	Acciones recomendadas	Resultado esperado
0-7 días	Confirmar QR_SECRET/AUTH_SECRET por ambiente, endurecer CORS, sanitizar errores, revisar usuarios seed, bloquear releases sin hash.	Reducción inmediata de riesgo de exposición, falsificación y arranque inseguro.
8-30 días	Endpoint RBAC completo, tenant scoping por empresa/operación, cifrado offline, validaciones Excel y migraciones versionadas.	Base comercial segura para múltiples clientes, buques y dispositivos.
31-90 días	Auditoría hash-chain, SIEM/log centralizado, rate limiting, jobs asíncronos, hardening DataWedge/MDM, firma de instaladores.	Mayor resiliencia operacional y trazabilidad forense.
90+ días	Pentest externo, ejercicios DR, matriz de cumplimiento, monitoreo de proveedores IA/AIS/clima y evaluación SOC2/ISO 27001.	Preparación para venta corporativa y auditorías de clientes enterprise.

Pruebas de regresión de seguridad sugeridas

1. Dos operaciones abiertas simultáneas: validar que ninguna guía, SOF, reporte o cache mezcle operación_id. 2. Chofer bloqueado: sus guías pasan a pendientes de reasignación y QR quedan inactivos. 3. Cuota cumplida: nuevas asignaciones quedan bloqueadas y alertadas. 4. QR manipulado: falla tanto online como offline. 5. Handheld sin red: guarda local, reintenta y sincroniza sin duplicar escaneos. 6. Usuario por empresa: no ve datos de otra empresa aunque pertenezca al mismo buque.

Conclusión Senior

XTRAVON ONE ya incorpora controles que muchos sistemas operativos portuarios no tienen en fases tempranas: QR con firma, escaneo por etapas, flujo offline, roles, TOTP, auditoría, despacho, liquidaciones y trazabilidad por operación. El siguiente salto no es agregar más pantallas, sino formalizar la capa de seguridad comercial: aislamiento por cliente, permisos por acción, cifrado local, releases firmados, auditoría inmutable y pruebas automatizadas de abuso de negocio. Con esas correcciones, el sistema puede posicionarse como una plataforma robusta para control de granos, mitigación de pérdidas, evidencia operativa y cumplimiento ante clientes enterprise.

Dictamen: **apto para piloto controlado** con operación real supervisada, siempre que se cierre el backlog de seguridad alta antes de escalar a múltiples clientes/países.